

Аудит IT-инфраструктуры предприятия партнёра

Проект: FMCTS — интеллектуальная платформа краткосрочного прогнозирования на основе нечётких цепей Маркова

Партнёр: Попов Валерий

Проверяющий: Гончаров Андрей

Смоделированная IT-компания: ООО «ФазиМарк Тех» (FuzzyMark Tech) — разработчик и интегратор FMCTS

1. Описание предприятия

Название: ООО «ФазиМарк Тех»

Сфера деятельности: разработка, внедрение и сопровождение SaaS-платформы для прогнозирования динамических систем и торговых сигналов

Размер: 42 сотрудника (11 разработчиков, 6 Data Science/Quant, 4 DevOps/MLOps, 7 техподдержка и клиентский сервис, 6 аналитика/продажи, 8 административный блок)

Бизнес-процессы, зависящие от IT:

- 1. Разработка и поставка продукта (CI/CD, релизы, контроль качества кода)
- 2. Прогнозирование и генерация сигналов в режиме near real-time (ядро FMCTS, API)
- 3. Клиентское обслуживание и мониторинг SLA (поддержка, отчётность, алертинг)

Роль IT: критическая. При деградации инфраструктуры сервис теряет точность/скорость и не выполняет SLA для клиентов.

Основные IT-системы:

Разработка: GitLab, Jira, Docker Registry, SonarQube

Продуктовый контур: API Gateway, сервис прогнозирования FMCTS, PostgreSQL, Redis

Наблюдаемость: Prometheus, Grafana, Alertmanager, Loki

Внутренние: 1С:УНФ, корпоративный портал, база знаний

2. Инвентаризация IT-инфраструктуры

Аппаратное обеспечение (10+ позиций)

Тип	Модель	ОС	Кол-во	Состояние
Сервер приложений FMCTS	Dell PowerEdge R750 (128GB RAM)	Ubuntu 22.04	3	Хорошее
Сервер БД (primary)	HPE ProLiant DL380 Gen10	Debian 12	1	Хорошее
Сервер БД (replica)	HPE ProLiant DL380 Gen10	Debian 12	1	Хорошее
Сервер мониторинга	Supermicro 2U (64GB RAM, SSD+HDD)	Ubuntu 22.04	1	Удовлетворительное (HDD под износ)
Сервер логирования	Dell R640	Ubuntu 22.04	1	Хорошее

Сервер резервного копирования	QNAP TS-h1288X	QTS	1	Хорошее
Тип	Модель	ОС	Кол-во	Состояние
Рабочая станция разработчика	Dell Precision 3660	Windows 11	11	Хорошее
Рабочая станция аналитика	Lenovo ThinkCentre M75s	Windows 11	6	Хорошее
Ноутбук поддержки	MacBook Pro M1/M2	macOS	7	Хорошее
Офисный ПК	Dell OptiPlex 3090	Astra Linux	8	Удовлетворительное (части ПК не хватает RAM)
Маршрутизатор ядра	MikroTik CCR1036	RouterOS	2 (HA)	Хорошее
Коммутатор доступа	Cisco Catalyst 2960-X	IOS	3	Устаревает

Общая оценка: инфраструктура достаточна для текущего масштаба, но сервер мониторинга и часть офисных ПК требуют модернизации.

Программное обеспечение

ОС: Ubuntu 22.04, Debian 12, Windows 11, Astra Linux, macOS

БД и middleware: PostgreSQL 14/15, Redis

Прикладное ПО: GitLab, Jira/Confluence, Prometheus, Grafana, Alertmanager, Loki, 1C:УНФ

Лицензирование: корпоративные лицензии на коммерческое ПО, для OSS-компонентов соблюдаются условия использования

Сетевая инфраструктура

Локальная сеть: 1 Гбит/с, сегментация VLAN (prod, staging, management, office, guest)

Интернет: два провайдера с автоматическим failover

Доступ: WireGuard/OpenVPN для удалённых сотрудников

DMZ: для публичных API и веб-интерфейса

3. Безопасность IT-инфраструктуры

Анализ рисков (3+ угрозы)

Угроза	Вероятность	Потенциальный ущерб	Существующие меры	Эффективность
--------	-------------	---------------------	-------------------	---------------

Утечка API-ключей/ секретов	Средняя	Доступ к клиентским данным, компрометация сигналов	Секреты в vault, ротация части ключей, аудит доступа	Средняя (ротация не везде регулярна)
DDoS на публичный API	Средняя	Недоступность сервиса, нарушение SLA	Rate-limit, WAF у провайдера, алерты	Средняя
Угроза	Вероятность	Потенциальный ущерб	Существующие меры	Эффективность
Компрометация цепочки поставок зависимостей	Средняя	Внедрение вредоносного кода в сборки	Проверка репозитории, code review	Ниже средней (нет полного SBOM/подписи артефактов)
Отказ сервера мониторинга	Средняя	Потеря наблюдаемости и позднее обнаружение инцидентов	Бэкапы и RAID	Средняя (есть SPOF на уровне роли)
Потеря ключевого специалиста	Средняя	Задержка в остановлении и развития	Частичная документация, парное ревью	Средняя-низкая

Оценка мер безопасности

Антивирус/EDR: включён на пользовательских устройствах и критичных узлах

Сетевые меры: VLAN, firewall, ограничение mgmt-доступа

Политика паролей: формализована; MFA включена в критичных системах, но не в полном охвате

Резервное копирование: ежедневно локально + еженедельно в облако

DR-подход: базовые процедуры есть, но формальные RTO/RPO и регулярные учения не зафиксированы

Итог: базовый уровень защиты достаточен для операционной деятельности, но для роста клиентской базы нужна формализация resilience-контура.

4. Рекомендации по управлению проектом модернизации

Цель: повысить устойчивость и масштабируемость платформы до режима 100+ активных клиентов с контролируемым SLA.

Задачи:

1. Устранить SPOF в мониторинге и логировании
2. Формализовать DR-процедуры с RTO/RPO и ответственными
3. Усилить supply-chain security (SBOM, сканирование и подпись артефактов)
4. Нормализовать процесс эскалаций и runbook для критичных метрик

План проекта (4 этапа)

Этап	Содержание	Срок	Ответственный
1	Аудит текущего контура и закупка оборудования для отказоустойчивого мониторинга	1 месяц	DevOps Lead
Этап	Содержание	Срок	Ответственный
2	Развёртывание отказоустойчивого observability-контура (2–3 узла, резервирование)	2 месяца	SRE/DevOps команда
3	Формализация DR Plan: RTO/RPO, роли, триггеры активации, runbook top-5 аварий	1 месяц	IT Service Manager
4	Проведение DR-drill и обновление регламентов (post-mortem + knowledge base)	1 месяц	Поддержка + DevOps

Управление рисками проекта

Риск	Вероятность	Меры смягчения
Перегрузка команды в период модернизации	Высокая	Позапный rollout, фиксация приоритетов, временный внешний ресурс
Регрессии при миграции observability	Средняя	Тестовый стенд, обратимый план переключения
Рост затрат выше плановых	Средняя	Контроль бюджетных гейтов, резерв 10–15 процентов

Ошибки в DR-сценариях	Средняя	Репетиции и quarterly drills с фиксацией KPI восстановления
-----------------------	---------	---

Коммуникации

Внутренние участники: DevOps/MLOps, разработка, поддержка, продукт, финансы

Внешние: клиенты и партнёры (плановые уведомления о работах и изменениях SLA)

Каналы: Slack/Teams, дашборд в Confluence, аварийный канал в Telegram

5. Сильные стороны

Связка бизнес-метрик и технических метрик уже заложена в проекте

Используется двойной интернет-провайдер и сегментация сети

Финансовая модель проекта детально проработана (TCO/ROI/NPV)

Есть база ITIL-процессов и регламентов для операционного управления

6. Замечания

Не везде формально закреплён владелец метрик и ответственность за эскалацию

DR-процедуры описаны частично, но не доведены до регулярных учений

В контуре безопасности зависимостей отсутствует полноценный SBOM-подход

Наблюдаемость имеет риск SPOF в текущей конфигурации мониторинга

7. Итоговые рекомендации (приоритеты)

P0: зафиксировать RTO/RPO, владельца активации DR и top-5 disaster runbook

P0: устранить SPOF мониторинга (кластер/резервирование) и протестировать фейловер

P0: нормализовать матрицу эскалации (severity, SLA реакции, on-call роли)

P1: внедрить supply-chain security практики (SBOM, сканирование зависимостей, подпись артефактов)

P1: централизовать операционную документацию и post-mortem практику

Ожидаемый эффект: повышение устойчивости инфраструктуры ориентировочно с 6/10 до 8/10, снижение риска критических простоев и более предсказуемое выполнение SLA.